Mandatory Appendix B — AI Critique (200–300 words)

Sinh viên: TRƯƠNG THÀNH PHÁT — **MSSV:** 23120319 — **Lớp:** CQ2023/3
Môn học: Kiểm thử phần mềm (CSC13003) — **Học kỳ:** HK1/2026-2027

Quá trình kiểm thử EShop bộc lộ nhiều điểm yếu và thiên kiến của AI. Thứ nhất, AI mắc thiên kiến chức năng (Functional Bias): tại FR-03 (A08, A12), khi API trả về OTP trong response, AI xem đây là dữ liệu hợp lệ thay vì nhận diện lỗ hổng lộ thông tin nhạy cảm (CWE-200). Tại FR-08 (A20, A21), AI thụ động coi tổng tiền là biến đầu vào độc lập, bỏ qua lỗi thao túng giá (Parameter Tampering) trên Web. Tại FR-12 (A27), AI nhầm lẫn giữa xác thực và phân quyền, ngộ nhận middleware authenticateToken đã bảo vệ an toàn các route quản trị dù thiếu kiểm tra vai trò admin.

Các sai sót này xuất phát từ ba nguyên nhân: (1) Giới hạn công cụ (Tool limitation): AI bị chi phối bởi các mẫu code chuẩn, không tự nhận biết tác dụng phụ môi trường runtime; (2) Chất lượng prompt (Prompt quality): Prompt ban đầu chỉ tập trung vào hành vi danh định, chưa định hướng kiểm tra bảo mật và toàn vẹn dữ liệu; (3) Độ phức tạp tính năng (Inherent complexity): Quy trình stateful như chuỗi token động (FR-03) hay phân quyền phân tầng (FR-12) đòi hỏi ngữ cảnh thực thi đa bước.

Bài học cốt lõi rút ra là nguyên tắc "Zero-Trust SUT" và vai trò quyết định của con người (Human-in-the-loop). AI là trợ lý sinh phân hoạch và ca kiểm thử đắc lực, nhưng người kiểm thử phải luôn giữ tư duy phản biện, trực tiếp thẩm tra mã nguồn và đối chiếu kết quả thực thi thực tế để bù đắp điểm mù của mô hình.